

| ITEM | CATEGORÍA                                      | CHECKLIST<br>(Qué se verifica?)                                                                                                             | ¿Cómo se verifica?                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|------|------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A1   | Inyección                                      | <b>¿Se puede acceder a los datos con seguridad?</b><br><b>¿Están bien definidos los roles ?</b>                                             | <ol style="list-style-type: none"> <li>1. Ingresar desde la ruta de login desde la aplicación y validar que esté activo el https desde el navegador y después de ingresar validar el network (consola de desarrollador) u otra herramienta que permita capturar la transmisión de datos (SELENIUM).</li> <li>2. Verificar desde la cuenta del administrador de la aplicación si se puede crear usuarios con diferentes roles y autenticarse luego. (posteriormente pasar la verificación número 1)</li> </ol>                                                                                      |
| A2   | Pérdida de autenticación y gestión de sesiones | <b>¿Las sesiones expiran después de un tiempo de inactividad?</b><br><b>¿Se protege el inicio de sesión contra ataques de fuerza bruta?</b> | <ol style="list-style-type: none"> <li>1. Iniciar sesión en la aplicación. Dejar la sesión inactiva por un tiempo, por ejemplo 30 minutos. Intentar realizar una acción y verificar si el sistema redirige al login o muestra mensaje de sesión expirada. (selenium).</li> <li>2. Intentar ingresar con credenciales incorrectas por lo menos 5 veces seguidas y verificar si el sistema bloquea temporalmente el acceso y luego posteriormente mostrar CAPTCHA o notificar al administrador y para finalizar revisar los logs de seguridad para alertas de intentos fallidos (Jmeter).</li> </ol> |

|    |                            |                                                                                                                                                                  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
|----|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A3 | Datos sensibles accesibles | <p><b>¿Los datos sensibles (contraseñas, tarjetas, documentos, etc.) están cifrados?</b></p> <p><b>- ¿Se pueden ver datos personales sin estar logueado?</b></p> | <ol style="list-style-type: none"> <li>1. Es posible acceder a la aplicación sin iniciar sesión y de acceder directamente a rutas que contengan datos delicados (como /perfil, /cuenta etc.) para verificar si el sistema restringe el acceso.</li> <li>2. Iniciar sesión en la aplicación revisando si las respuestas tienen información delicada en texto plano, tanto en el contenido visible como en el código fuente</li> <li>3. Cerrar sesión y ver si se pueden visualizar de nuevo esas rutas sin autenticación, asegurando que no se conserve acceso a los datos personales.</li> </ol> |
|----|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

|    |                              |                                                                                                                                                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|----|------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A4 | Entidad externa de XML (XXE) | <b>¿La aplicación procesa archivos XML?</b><br><b>¿Están deshabilitadas las entidades externas y DTD en el parser XML?</b>                                | <ol style="list-style-type: none"> <li>1. Determinar si la aplicación permite la carga de archivos XML a través de formularios, puntos de acceso o integraciones.</li> <li>2. Mandar un archivo XML que tenga una entidad externa definida (como una referencia a un archivo del sistema) y evaluar si el sistema la procesa o la rechaza.</li> <li>3. Examinar la respuesta del sistema para comprobar si se omitió la consideración de las entidades externas y si el parser XML no analiza instrucciones de clase <code>&lt;!ENTITY&gt;</code> ni DTDs.</li> </ol> |
| A5 | Control de acceso inseguro   | <b>¿Puedo ver páginas como /admin o /panel sin iniciar sesión?</b><br><b>- ¿Puedo cambiar el número de un ID en la URL y ver datos de otros usuarios?</b> | <ol style="list-style-type: none"> <li>1. Recorrer las rutas restringidas que requieran login (/admin, /panel...) sin haber realizado el logueo de un usuario y comprobar si el sistema deja acceder o enviar al logueo.</li> <li>2. Iniciar sesión con un usuario común y cambiar manualmente parámetros en la/url (por ejemplo, un ID numérico) para intentar acceder a la información de otros usuarios.</li> <li>3. Comprobar que el sistema cuenta con controles de acceso sobre roles y restricciones por usuarios.</li> </ol>                                  |

|    |                                       |                                                                                                                                                                                                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|----|---------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                                       |                                                                                                                                                                                                |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| A6 | Configuración de seguridad incorrecta | <p><b>¿Los servicios/APIs tienen configuraciones por defecto (credenciales admin:admin, puertos abiertos)?</b></p> <p><b>¿La aplicación usa protocolos inseguros (HTTP, FTP, TLS 1.0)?</b></p> | <p>1. Llevar a cabo un análisis de la red para encontrar todos los puertos abiertos y todos los servicios activos sobre el servidor, comprobar si esos servicios visibles (de paneles de administración, de bases de datos o herramientas como Jenkins), permiten el acceso sin obrarse completamente la seguridad, por ejemplo, contraseñas por defecto, sin autenticación, etc. (selenium),</p> <p>2. para comprobar si la aplicación usa protocolos inseguros (HTTP, FTP, TLS 1.0), se puede comprobar la URL, si esta empieza por 'http', es una buena señal para indicar que se usa un protocolo inseguro.</p> |
| A7 | Cross site scripting (XSS)            | <p><b>¿Los campos de entrada (formularios, URLs, parámetros) sanitizan código malicioso?</b></p> <p><b>¿Los almacenamientos (BD, caché) filtran XSS almacenado?</b></p>                        | <p>1. Se comprueba enviando los diferentes datos maliciosos por los distintos campos de entrada de la página (como formularios) para observar si el site los ejecuta de forma insegura, de tal modo que pudiéramos estar listos ante un ataque</p> <p>2. Se comprueba enviando el contenido malicioso (como realizar comentarios con código sospechoso) y observando si el site lo</p>                                                                                                                                                                                                                              |

|    |                         |                                                                                                                                                                                             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|----|-------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|    |                         |                                                                                                                                                                                             | ejecuta o si, cuando se carga la página, también se muestra un componente peligroso                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| A8 | Decodificación insegura | <p><b>- ¿Puedo subir imágenes o archivos con extensiones sospechosas y el sistema los acepta?</b></p> <p><b>- ¿El sistema ejecuta directamente archivos que subo (como .php o .js)?</b></p> | <ol style="list-style-type: none"> <li>1. Usar Selenium para que este sistema acepte la carga de archivos con extensiones no válidas (.php, .js, .exe) y comprobar si acepta en el sistema el archivo subido o muestra un mensaje de rechazo.</li> <li>2. Mediante Selenium acceder a la ruta de almacenamiento del archivo subido, comprobando que se descargue o que se interprete como código por el navegador.</li> <li>3. Comprobar el comportamiento del sistema al abrirlo desde la interfaz del sistema para confirmar que no se ejecute directamente un contenido potencialmente malicioso.</li> </ol> |

|     |                                        |                                                                                                                                                                                                                           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|-----|----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| A9  | Componentes con vulnerabilidades       | <p><b>¿Se usan librerías/frameworks con vulnerabilidades conocidas (CVE)?</b></p> <p><b>¿Los dispositivos IoT/embedded ejecutan firmware vulnerable?</b></p>                                                              | <ol style="list-style-type: none"> <li>1. Revisar las dependencias del proyecto y Dependency-Check para escanear vulnerabilidades.</li> <li>2. Revisar la versión del firmware que están utilizando, ya sea desde la interfaz web del dispositivo o desde la información que nuestra aplicación recoja y muestre, se consulta en la bases de datos de vulnerabilidades como CVE, NVD o Shodan, buscando si esa versión del firmware tiene fallos de seguridad conocidos.</li> </ol>                                                                                                            |
| A10 | Insuficiente monitorización y registro | <p><b>¿Se registran eventos críticos (inicios de sesión, accesos fallidos, cambios de configuración)?</b></p> <p><b>¿Los logs contienen información suficiente para análisis forense (timestamps, IPs, usuarios)?</b></p> | <ol style="list-style-type: none"> <li>1. Revisar el sistema de logs del backend (por ejemplo, archivos de log, bases de datos, o servicios de monitoreo) para ver si estos eventos quedan registrados. Se puede simular estos eventos (ejemplo hacer un intento de login fallido) y comprobar que eventos se loguean.</li> <li>2. Revisar el englobe del sistema de logs de la aplicación o del backend y que se registren eventos tales como inicios de sesión, intentos de inicio de sesión fallidos, cambios de contraseña o de configuración, entradas a áreas sensibles, etc.</li> </ol> |

|  |  |  |  |
|--|--|--|--|
|  |  |  |  |
|--|--|--|--|